Scoping Document D2
Unit: COMP3850, Macquarie University
Project Sponsors: Macquarie University School of Computing
Team: 74
Version: 3.0 5/09/2026

Revision History

Version	Date	Author(s)	Summary of changes
1.0	13/08/2026	[Jaden Ha]	Initial scoping content (D1 set).
2.0	05/09/2026	[Jaden Ha]	D2 submission against the Cybersecurity scoping template.
3.0	01/10/2026	Omar Ali Rahman, Jaden Ha	D3 update: refocused detection / feature / analysis sections (5, 10, 11) onto the project's real PPRL threat model; added client-feedback and presentation sections and references; incorporated sponsor feedback.
4.0	23/10/2026	Jaden Ha	Further updates based on D2 & D3 feedback, and MVP

1. Document Conventions and Intended Audience

Document Structure

This document follows the 17 section structure prescribed by the Cybersecurity Scoping Document template issued with the Project Deliverables Definition (PDD). Sections 1 and 2 establish conventions and scope. Sections 3 to 5 address the threat environment the project defends against. Sections 6 to 11 cover assumptions, data and analysis. Sections 12 to 15 cover defensive solution, architecture, evaluation and its handover. Sections 16 and 17 cover client feedback and presentation.

Heading and Numbering Style

Sections are numbered to a maximum of 3 levels. Tables and figures are numbered sequentially and referenced in the body text. Formulae along with source code, identifiers, file names and library names. are presented in words so that they remain readable.

Formatting Conventions

The document uses consistent heading levels, font, sequential section numbering, and a revision history at the front as required. Australian English spelling is used throughout the documents.

Intended Audience

This document addresses:
Project Sponsors - Macquarie University School of Computing (Dr Dinusha Vatsalan and Piyumi Senviratne) are the client for this work. Their interest is in whether the team has correctly understood the objectives, the data and the algorithms, and whether the planned evaluation will produce results they can use.
Unit Convenor and Assessors - COMP3850 teaching staff assess this document against the published rubric.
Project Team - Defensive Team 74 will be using this shared reference document which serves as the reference for scope, assumptions, terminology, algorithms and test plans.

Acronyms and Abbreviations

- Privacy Preserving Record Linkage (PPRL): identifies records across databases held by different parties that refer to the same entity, without those parties exchanging raw personal identifiers.
- Quasi Identifier (QI): an attribute that is not a unique identifier on its own but which, in combination with others, can identify an individual (e.g. name, city, zipcode).
- Entity identifier: unique code or value that distinguishes a specific person, organisation, or object from all others in a database.
- Bloom Filter (BF): fixed length binary vector encoding used to check whether an item might be inside a list or set without needing to store the actual items.
- Counting Bloom Filter (CBF): variation of the Bloom filter holding integer counters rather than binary values.
- Differential Privacy (DP): mathematical system that lets people study group data while keeping individual details safe.
- Randomised response: survey research method used to collect accurate data on sensitive, illegal, or stigmatised topics while protecting the participant's privacy.
- Epsilon: differential privacy budget parameter.
- Precision/ recall/ F1: linkage quality metrics derived from the confusion matrix.

- Machine Learning (ML): branch of artificial intelligence that gives computers the ability to learn from data and improve over time without being explicitly programmed.
- Membership Inference Attack (MIA): data privacy attack where an adversary queries a machine learning or artificial intelligence model to figure out if a specific data point was used to train that model.
- Minimum Viable Product (MVP): most basic version of a new product that has just enough core features to satisfy early users and test a business idea in the real world.
- Sensitive attribute: data that requires extra protection because exposing it can cause privacy risks, security harm, or compliance violations.

2. Purpose and Project Scope

Project Goal and Scope

The project extends an existing 2 party privacy preserving record linkage (PPRL) pipeline and produces a comparative experimental evaluation of the result. The sponsors have defined two objectives:

1. Implement an encoding function for unstructured text data, using counting Bloom filters (CBF) so that token frequency is preserved.
2. Implement 4 additional linkage models, drawn from supervised machine learning (ML), to compare and evaluate the linkage quality, computational efficiency and privacy.

In Scope:

- Two party linkage between the supplied code and datasets.
- Four additional linkage models, drawn from supervised machine learning.
- Implementing counting Bloom filter encoding function on the supplied text datasets and testing it with at least one linkage model.
- Comparative evaluation of all five linkage models on linkage quality, computational efficiency and privacy.
- Final report presenting the experimental results with discussion and the final source code (along with other COMP3850 deliverables).

Out of Scope:

- Attack implementation: our team is focused on the defence stream.
- Multi party linkage: the sponsors have confirmed the project investigates two party linkage only.
- Data cleaning and preprocessing of the structured datasets: the sponsors have confirmed the supplied datasets are already clean.

Motivating Factors

As organisations hold separate databases of patients and customers, it is difficult to provide valuable analysis of those individuals without encompassing the data from those multiple different sources. However, no unique entity identifier is shared between them, so linkage must rely on the quasi identifiers common to all sources.

This leads to the sponsor's main problem: the attributes required to perform the linkage must meet privacy and confidentiality obligations to prevent organisations from disclosing raw identifying data to one another.

3. Attacks and Vulnerability Understanding

Relevant Vulnerabilities and Attack Vectors

Cryptanalysis (Frequency) attacks
Bloom filter encodings preserve the frequency distribution of the underlying values such as common surnames and thereby produce common bit patterns. Adversaries that know the population distribution can align observed encoding frequencies with known value frequencies and recover plaintext values without breaking hash functions.

Re-identification (Linkage) attacks
Patients' identities can be revealed when quasi-identifiers, which uniquely identifies one or many individual's data points, are present in the data. Adversaries are able to achieve this by combining the data with other information.

Why these Vulnerabilities Matter

These vulnerabilities matter because they represent two different failures of anonymisation. It shows the weaknesses of the privacy protection system as adversaries are able to exploit software bugs or gain unauthorised system access to identify patients. The problems are present in real world systems that handle sensitive data (i.e. health records, surveys, biometric matching) which is why the sponsors have stressed the importance of privacy in this project.

Attack Surface Diagram

Vulnerability/ Attack Vectors	System Component
Cryptanalysis (Frequency) attacks	Counting/ Bloom filter encoding
Re-identification (Linkage) attacks	Quasi-identifiers

4. Adversary Profiles

Adversaries - Goals and Motivations

External Adversary
Unauthorised personnel with no legitimate access to the PPRL system who attempt to exploit exposed vulnerabilities. Their goal would be to reconstruct quasi identifiers encoded in intercepted or leaked Bloom filters, and reidentify the individuals they describe. Without legitimate access to the systems, they obtain encoded records opportunistically through methods such as interception in transit, a data breach at one party, or an encoded dataset released. However, the dataset is sampled from a publicly obtainable population dataset (North Carolina voter registration records), in which adversaries could potentially acquire the actual source of names, cities and postal codes. The capabilities of the external adversaries can range from q-gram mapping offline to performing frequency analysis.

Curious/ Malicious Counterparty
A party that has access to the PPRL (i.e. Alice or Bob) who look to gain information from the other party's database, beyond the matched set they are entitled to, or attempt to manipulate the linkage outcome through techniques such as crafted record injections to probe the encoding/ to force matches. The adversary can utilise these techniques to confirm whether a specific individual appears (membership inference) in the other party's data. Their access is legitimate as they receive the other party's full set of encoded records as per protocol. Their knowledge includes everything the external adversary knows plus their own plaintext database. Their resources include institutional computing capacity, a legitimate standing in the arrangement, and the ability to accumulate encoded records across repeated linkage exercises over time. Their capabilities range from mounting a plaintext attack directly through encoding their own records and comparing the resulting bit patterns against the counterparty's filters, performing membership inference by encoding a target individual's details and testing for a high similarity match and injecting crafted records into their own input to prove the encoding or to force matches. These capabilities utilise data that the malicious counterparty legitimately holds, and thereby can appear to be following the protocol and can get away with such attacks, hence making these attacks more attractive.

Malicious Insider
Approved personnel that have access to the full set of pre-encoded records and code that may attempt to alter/delete, duplicate, and distribute the resources without permission. With their level of access privilege, malicious insiders can reach raw records before encoding, source code, hyperparameter configuration, and the entity identifier column which is used as ground truth. Their level of knowledge is complete and requires no auxiliary data and no interference, and their resources are also complete with full authorised access. The capabilities of the malicious insider include, copying or distributing raw records directly (rendering encoding obsolete), alter or delete records and encoded outputs, and modifying configuration to weaken

protection without altering any data such as by raising the privacy budget or lengthening the Bloom filter to reduce collisions.

5. Attack and Vulnerability Detection

Detection Methods

Pipeline Evaluation Techniques
Collision rate will be measured and reported by the encoding function in the supplied pipeline. It quantifies the ambiguity introduced by collisions, a mechanism Bloom filters resist recovery.
Privacy budget epsilon will indicate guarantee strength provided by the randomised response layer.
Comparisons against the 2 supplied baselines will isolate how much protection each defensive layer contributes.

File Access Monitoring
Access to project resources including code and datasets will be only accessible to approved users:

- Unrestricted access of all Project Team members of all team resources
- Access to deliverable resources for Sponsors

In regards to the project code, repository activity and version history on Github will be monitored to deter unwarranted actions and detect suspicious activities.
Repeated failed login attempts of the Github repository will also be monitored through Github account security.

6. Monitoring of Assumptions

The project runs on the following assumptions. The table below records current assumptions, the consequences of an invalid assumption, and how each is monitored.

Assumption	Risks if Invalid	Monitoring Approach	Status
All provided datasets and resources remain unchanged and available for the duration of the project	Can hinder testing and development outcomes	Confirm with sponsors, and holding a copy of the original datasets and other resources	Valid
Supplied datasets are true and suitable for developing the	Can hinder testing and development outcomes	Confirm with sponsors	Valid

project models			
The project implementation platform is Python	Will create availability issues	Confirm with sponsors	Valid
Existing Bloom filter and differential privacy components run as intended	Affect encoding function outcomes	Testing current and existing pipeline before adding components	Valid
The evaluation metrics supplied in the codebase are complete and correct	Corrupt evaluation model of project and therefore unreliable results	Testing with a control baseline variable to ensure evaluation works as intended	Valid
Weekly sponsor meetings and email support continue for the project duration	Hinder project development progress	Confirm with sponsors	Valid

The register is reviewed at the internal team session preceding each sponsor meeting, and any assumption that has moved to open or is at risk is added to the consolidated question list for that meeting.

7. Data Quality

Expected Data

The project will utilise data that is supplied by the sponsors through the project Teams channel. The two structured data are named Alice and Bob which have been sampled from North Carolina voter registration data. The data is structured by 5 columns, with column 1 recording ID used as the entity identifier. Columns 2 to 5 are the quasi identifiers which include surname, first name, city and zip code. Both the datasets come in two sizes being 100 records and 500 records, which have a deliberate corruption at three levels: 0%, 25% and 50%. These corruptions include things such as errors and variations. The sponsors have also provided unstructured text datasets which will be used later in the project.

Data Issues

The test condition is corruption, so that the project can measure how errors and variations affect the linkage quality. It is also important to note that corruption compounds with privacy noise, therefore any conclusion drawn about the linkage model must state the corruption rate it was measured at.

8. Data Preparation

Preprocessing Steps

Structured data
No cleaning is required as confirmed by the sponsors, as they have been already cleaned, standardised and preprocessed. The corruption is required so that it can test whether the linkage solution can still identify them as the same person across two differently formatted databases.

Workflow Diagram:
Supplied dataset → blocking → Bloom filter encoding → differential privacy perturbation → matching

9. Data Collection

What Data will be Collected and Stored

No data is to be collected as all datasets are supplied by the project sponsors and retrieved from the project Teams channel. Within the channel, materials are organised under Shared, with slides and background readings available under Materials, and separate folders holding the datasets, the source and the meeting recordings.
Github will be used as an additional source of storage to keep the datasets.

10. Security Feature Extraction

A closer look at the security features of the project, reveal the importance of monitoring how data is handled. From the fundamentals such as failed logins and network traffic through to the more sophisticated encoding component, it is crucial to understand their roles and risks.

Failed login attempts lie as one of the first layers of protection for unauthorised personnel. It typically acts as a count or rate based feature that tracks the number of failed login attempts within a time window. For example, it can track the attempts per user, per IP address or per account to detect suspicious login activity and shut down further attempts upon detection by placing a lock on said login entry point. This is a common method to hinder brute force attacks, credential stuffing and account enumeration.

The monitoring of network traffic is not only crucial as to allow a smooth and reliable testing and evaluation environment for the Project Team, but also plays a greater security role in detecting deviations from the ‘normal’ network behaviour. These include observing components such as abnormal traffic volume, connections to/from unexpected IPs or ports, packet sizes or timing patterns to detect potential DDoS attacks, data exfiltration and port scanning. This process helps detect when attacks are taking place rather than a preventative measure to better respond to adversaries.

Lastly, the encoding component, in which the transformation that converts a quasi identifier into binary suitable for a linkage model is the protection. This is made possible by its distance awareness in Bloom filters, which allows it to compare different binary values in chunks and checks for neighbouring values to show similarity without compromising the privacy of the identifiers.

11. Attack and Vulnerability Analysis

It is vital to analyse attacks and vulnerabilities across the two stages, before an attack occurs (pre), and after it has been contained (post) to ensure a defensive framework that is continuously operating and adaptive.

Pre-Attack Stage

The purpose of this stage is to identify weaknesses before they are exploited.
Methods include:

- Recording a baseline establishment for each feature such as ‘normal’ failed login rates and traffic volume so that later deviations are measurable and assessed.
- Access control auditing through periodic review of user permissions such as project team access controls vs sponsor access controls.
- Threat modelling to map which attack types such as brute force, credential stuffing and DDoS attacks are effective against each system component.
- Reviewing defence configurations such as verifying lockout protocols, epsilon budgets, and baseline comparison schedules are all correctly configured before deployment.

Indicators of Compromise/ Behavioral Patterns:

- Misconfigured access permissions such as sponsors having project team level access.
- Absence of a defined privacy and lockout protocol.
- Unusual/abnormal measurements that deviate from the ‘normal’ baseline establishment record such as unusual traffic volume during off work hours, failed logins, and port scans.

Post-Attack Stage

The purpose is to confirm the incident is resolved to then learn from it and adapt defences.
Methods include:

- Log review and forensic reconstruction to piece together the full attack timeline using failed login logs, traffic captures, and Github repository commit history.
- Updating the ‘normal’ behaviour baseline if the attack revealed the previous baseline was too permissive.
- Policy adjustment such as tightening lockout protocol, increasing differential privacy by reducing per session epsilon allowances, and adjusting access tiers.

Indicators of Compromise/ Behavioral Patterns:

- Confirmed account compromised following brute force attack.
- Evidence of successful data exfiltration in traffic logs.
- Measurable drop in the encoding’s effective privacy guarantee.
- Unauthorised commits or resource access discovered in Github history.

12. Defence Countermeasures

Local preprocessing and encoding

Preprocessing and encoding are performed inside each organisation, so raw quasi identifiers never go outside the organisational boundary which eliminates the need for a trusted third party to receive plaintext identifiers and removes the risk. It addresses the potential vulnerability that depends on access to raw values, and leaves only insider access as the potential attack path. In the case of a malicious insider, systems such as version history and user access logs are in place to identify them.

Bloom filter encoding

Quasi identifiers are encoded into binary vectors via q gram hashing for strings, neighbourhood sets for numerical values, and direct hashing for categorical values. This way adversaries observing a set bit can not determine which q gram sets it as multiple q grams map to the same position. Protection level is able to be tuned through shortening the filter or increasing the collision rate through increasing the number of hash functions. However, it comes with limitations where the encoding can be vulnerable to cryptanalysis and frequency based attacks.

Counting Bloom filter encoding

In counting Bloom filters, free text is encoded, that preserve term frequency, which retains more exploitable features than a binary Bloom filter with the same parameters. The defensive implication is that text encodings require stronger perturbation, shorter filters or both in comparison to structured encodings. These qualities must be addressed in the development.

Differential privacy

A number of bit positions determined by the privacy budget is selected at random and flipped (randomised response), yielding epsilon differential privacy. This countermeasure provides a guarantee against external adversaries with public auxiliary data, in which the Bloom filter layer may struggle to assure.

13. Architecture, Algorithms, and Models

System Architecture

The system is a two party privacy preserving record linkage (PPRL) pipeline (Alice and Bob). Each performs preprocessing and encoding locally so that the raw quasi identifiers never leave the organisation. Encoded and perturbed records are then compared, classified as matches or non matches, and the resulting matched pairs are the output.

The pipeline runs in the following manner:
Local preprocessing → blocking → encoding into counting/not counting Bloom filters → differential privacy perturbation → record linkage → evaluation

Algorithms

Bloom filter encoding
For a string attribute, the value is decomposed into q grams using a sliding window of length q. Each q gram is hashed by each of the k hash functions, and the but at each resulting position is set to one. Encoding “Smith” produces the q grams SM, MI, IT, and TH, whereas encoding “Smit” produces SM, MI, and IT. Because three of the four q grams are shared, the resulting filters overlap and return a high similarity score, whereas hashing the whole strings would produce unrelated vectors and a similarity near zero. For numerical attributes, a set of neighbouring values around the true value is generated and hashed, therefore values of 17 and 18 share most of their neighbours, whereas values of 16 and 25 share fewer. And lastly, for categorical attributes, the value is hashed directly as there are a set amount of options.

Counting Bloom filter encoding
A counting Bloom filter is a variation of the Bloom filter that holds integer counters rather than binary values. It works through preprocessing the free text and extracting a bag of words, there it assigns each term a weight. Applies each term with each of the k hash functions, and at each resulting position, the counter is incremented by the term’s weight rather than setting a bit to one.

Differential privacy

The number of bit positions determined by the privacy budget epsilon is selected at random and flipped. Smaller values indicate greater strength (guarantee), however comes at the cost of weaker similarity signal (due to more noise disturbing the encoding) hence reducing the linkage quality.

Linkage models

The sponsor supplies a threshold based baseline, which classifies a pair as a match where similarity exceeds the configured threshold.
The project requires the team to implement the following models:

- Logistic regression
- Random forest
- Support vector machine
- XGBoost

14. Security Testing

Testing Strategy

The testing is a comparative experimental evaluation, in which the four PPRL models are measured against two internal baseline models. The testing will be conducted within a controlled parameter environment, on data with known ground truth. And finally, it should test upon the project's requirements for privacy, computational efficiency and linkage quality.

Within the testing, it should perform:

- Correctness testing: establishes that the implementation does what it is supposed to
- Comparative evaluation: produces the experimental findings that satisfy the deliverable
- Validation of interpretation: establishes that an observed result is a genuine effect

Privacy Testing

Privacy testing measures how much the encoded records reveal about the underlying personal identifiers. The privacy budget epsilon is to be tested to confirm that the randomised response mechanism delivers the guarantee. However, as mentioned above, stronger privacy comes at the cost of reduced linkage quality and therefore this aspect must be correctly balanced with the other testing guidelines to provide optimal results.

Computational Efficiency Testing

Computational efficiency testing measures what the pipeline costs to run, that being the runtime. The supplied code captures with a timer around the whole process, in addition to memory consumption and the volume of encoded data that would be exchanged between the two

parties. Therefore team incorporated techniques such as blocking or indexing will be the variable to measure in comparison to the supplied blocking process.

Linkage Quality Testing

The linkage quality testing measures how accurately the system identifies records that refer to the same person. It will be tested for precision, recall and the F-measure, and will run across all three corruption levels so that each mode's degradation profile is visible, with the uncorrupted datasets as control variables, and in balance with privacy settings.

15. Deployment, Monitoring, and Reporting

Deployment

The project does not require a production deployment, however requires the final report and source code. The final source code must remain in Python, and will consist of the new encoding function and four additional machine learning linkage models.

Monitoring

Progress is monitored through weekly reports on ilearn along with the weekly sponsor meeting held on Tuesdays via Microsoft Teams, also supported by email to the sponsors and advisor. During sponsor meetings, teams are to raise any unanswered questions in regards to the project.

Internally, the team will monitor the project progress through a shared google drive folder containing all relevant documents, along with the group Github repository with the code.

Reporting

The final report is the primary deliverable and must contain the experimental results with discussion.

It should include:

- The comparative evaluation of all five linkage models across linkage quality, computational efficiency and privacy.
- The text encoding results.
- The effect of differential privacy noise on linkage quality.
- Limitations of the project

Training and Support for Client

No end user training is required, since the sponsors are domain experts in this field and the project is focused on research and testing outcomes. Support will take the form of documentation rather than instruction, which will include new functions, a short readme covering environment setup and how to reproduce each reported experiment.

16. Client Feedback

Client feedback is essential for guiding the team's direction. Upon client feedback, major changes can be made to better suit the required product. Feedback is obtained at each deliverable submission and at the prototype demonstration, and is recorded with the team's response in the relevant deliverable (see the Prototype & MVP Document).

Key feedback to date:

Sponsor feedback	**Response / action**
Prototype and results are satisfactory.	Proceeding to the remaining two models and the text encoder.
Add plots and graphs for the final version.	Results now presented as figures in the prototype document and the final report.
Requires justification of the number of hash functions k and the training method.	k justified empirically by a sweep (privacy saturates by k≈10); training uses entity-level cross-validation on the perturbed filters.
(D1) Reframe alternatives around privacy level.	Alternatives revised to: no privacy; Bloom filter only; Bloom filter + DP.

[Team to add the exact prototype-demo date and any further sponsor responses once received.]

17. Presentation

The project will be presented at the on-campus demonstration (D5, 6 November 2026): a 12-minute presentation plus 3 minutes of questions, including a live demonstration of the pipeline and the comparative results. Each speaker's name will appear on their slides. The presentation will summarise the problem, the five model comparison, the privacy/accuracy trade-off, and the final recommendation. It gives the team the opportunity to fully demonstrate the product and its implementations that were carefully selected for the sponsors, providing an environment for a realistic industry standard practice.

References

Schnell, R., Bachteler, T., & Reiher, J. (2009). Privacy-preserving record linkage using Bloom filters. BMC Medical Informatics and Decision Making, 9(1).
Vatsalan, D., Christen, P., & Verykios, V. S. (2013). A taxonomy of privacy-preserving record linkage techniques. Information Systems, 38(6).
Vatsalan, D., Karapiperis, D., & Verykios, V. S. (2022). An overview of Big Data issues in privacy-preserving record linkage (Encyclopaedia of PPRL). arXiv:2212.05682.
Christen, P. (2012). Data Matching. Springer.
[Team to format references in the unit's required citation style and add any further sources used.]